Glosario Avanzado de Ciberseguridad y Hacking Ético

Este documento presenta un compendio técnico de términos fundamentales orientados a profesionales de la seguridad ofensiva, analistas de operaciones de seguridad y pentesters. Cada definición ha sido adaptada y redactada con un enfoque técnico profundo para su estudio y aplicación práctica.

A

- **Análisis Forense Digital:** Metodología sistemática para la adquisición, preservación, análisis y presentación de evidencias digitales extraídas de soportes informáticos o redes tras la materialización de un incidente de seguridad.
- **Acceso No Autorizado:** Intrusión o vulneración de los controles de seguridad perimetrales o internos para interactuar con sistemas, servicios o datos careciendo de los privilegios correspondientes.
- **Autenticación:** Procedimiento criptográfico o lógico mediante el cual un sistema valida la legitimidad de las credenciales presentadas por una entidad (usuario, proceso o dispositivo).
- **Autenticación de Dos Factores (2FA):** Mecanismo de control de acceso que exige la validación mediante dos categorías independientes de factores (ej. algo que se sabe y algo que se posee).
- **APT (Amenaza Persistente Avanzada):** Campaña de ataques informáticos prolongada en el tiempo, altamente coordinada y sigilosa, ejecutada habitualmente por actores con alta financiación y recursos avanzados.

B

- **Backdoor (Puerta Trasera):** Mecanismo de acceso alternativo y subrepticio instalado en un sistema para sortear los controles de autenticación convencionales y asegurar la persistencia del operador.
- **Breach (Violación de Datos):** Incidente de seguridad en el cual información confidencial, privada o restringida queda expuesta, es exfiltrada o cae bajo el control de terceros no autorizados.
- **Botnet:** Infraestructura distribuida conformada por múltiples equipos infectados (zombis) gestionados de manera centralizada mediante servidores de Comando y Control (C2).

C

- **Cifrado (Encryption):** Transformación matemática de datos legibles (texto plano) en información cifrada (texto cifrado) mediante algoritmos y claves criptográficas para preservar su confidencialidad.
- **Ciberataque:** Ejecución de acciones malintencionadas orientadas a comprometer la disponibilidad, integridad o confidencialidad de los activos tecnológicos de una

organización.
- **Ciberdefensa:** Conjunto proactivo y reactivo de tecnologías, arquitecturas y procedimientos orientados a repeler agresiones en el ciberespacio.
- **Ciberinteligencia:** Disciplina enfocada en la recolección, procesamiento y análisis contextual de indicadores de compromiso (IoCs) y tácticas de adversarios para anticipar vectores de ataque.
- **Certificado SSL/TLS:** Credencial digital firmada por una Autoridad de Certificación (CA) que valida la identidad de un sitio web y habilita el establecimiento de un canal de comunicación cifrado.

D

- **DDoS (Denegación de Servicio Distribuidora):** Saturación deliberada de los recursos de red o procesamiento de un objetivo mediante flujos masivos de peticiones concurrentes provenientes de múltiples fuentes.
- **Defensa en Profundidad:** Principio arquitectónico de seguridad que despliega múltiples capas defensivas interdependientes para mitigar el impacto si una de ellas es vulnerada.
- **Desbordamiento de Búfer (Buffer Overflow):** Anomalía de software provocada al verter un volumen de datos superior al espacio reservado en memoria, permitiendo potencialmente la sobrescritura de registros de control y la ejecución arbitraria de código.
- **DNS Spoofing:** Suplantación de respuestas en el sistema de nombres de dominio con el propósito de desviar el tráfico legítimo hacia plataformas controladas por el atacante.

E

- **Exploit:** Script, fragmento de código o secuencia de comandos diseñada para aprovechar una debilidad de software específica y alterar el comportamiento esperado del sistema.
- **Endpoint (Punto Final):** Cualquier dispositivo informático conectado a una red corporativa (estaciones de trabajo, servidores, dispositivos móviles) que constituye una superficie de exposición potencial.
- **Evasión:** Técnicas de ofuscación y elusión empleadas por el software ofensivo o los operadores para eludir la inspección de sistemas de detección de intrusiones, sandboxes y soluciones EDR.
- **Escaneo de Vulnerabilidades:** Evaluación automatizada de activos de red e infraestructura para identificar fallos de configuración o versiones de software desactualizadas.

F

- **Firewall (Cortafuegos):** Sistema perimetral de control de tráfico encargado de permitir o denegar el tránsito de paquetes basándose en políticas de seguridad predefinidas.
- **Fuga de Información (Data Leak):** Liberación no intencionada o exposición pública de datos corporativos críticos debido a negligencias operativas o fallos de control.
- **Phishing:** Vector de ingeniería social basado en la suplantación de entidades de confianza mediante comunicaciones electrónicas para inducir al error al usuario y sustraer credenciales.

G

- **Gobernanza de Ciberseguridad:** Marco estratégico directivo que alinea las políticas de seguridad de la información con los objetivos de negocio y el apetito de riesgo corporativo.
- **Gray Hat Hacker:** Investigador de seguridad que explora vulnerabilidades sin autorización formal, pero sin intenciones destructivas, a menudo divulgando los hallazgos públicamente o notificando al fabricante.

H

- **Hacking Ético:** Auditoría ofensiva autorizada y legal que emplea las mismas metodologías de los atacantes para evaluar el nivel de resiliencia de una infraestructura tecnológica.
- **Hashing:** Función matemática unidireccional que convierte bloques de datos de longitud variable en una cadena alfanumérica de tamaño fijo, empleada para validar integridad.
- **Honeypot:** Entorno controlado e instrumentado que simula servicios vulnerables con el único propósito de atraer, registrar y estudiar las TTPs de actores maliciosos.

I

- **Intrusión:** Acceso ilegítimo que logra vulnerar las barreras de contención de una red o equipo informático.
- **Incident Response (Respuesta a Incidentes):** Protocolo estructurado para contener, erradicar y recuperar sistemas afectados por una brecha de seguridad informática.
- **IP Spoofing:** Falsificación de la dirección IP de origen en la cabecera de los paquetes IP para enmascarar la procedencia real de las conexiones de red.
- **IDS (Sistema de Detección de Intrusos):** Herramienta pasiva de monitorización que analiza el flujo de red en busca de anomalías o firmas asociadas a ataques conocidos.
- **IPS (Sistema de Prevención de Intrusos):** Solución activa de seguridad capaz de interceptar en línea y descartar tráfico malicioso de forma automatizada.

J

- **Jailbreaking:** Proceso técnico para eliminar los mecanismos de restricciones de fábrica impuestos en sistemas operativos móviles, obteniendo privilegios de superusuario.

K

- **Keylogger:** Software o hardware de interceptación diseñado para registrar de forma silenciosa cada pulsación de teclado realizada por la víctima.

L

- **Lavado de Información (Data Sanitization):** Proceso criptográfico o físico destinado a

la destrucción irreversible de datos almacenados en soportes magnéticos o digitales.
- **LDAP Injection:** Vulnerabilidad de inyección que surge al no sanitizar adecuadamente los inputs del usuario procesados por consultas dirigidas a servicios de directorio LDAP.
- **Lateral Movement (Movimiento Lateral):** Fase donde el atacante expande su radio de acción dentro de una red interna corporativa tras haber comprometido un nodo inicial.

M

- **Malware:** Término genérico que engloba cualquier desarrollo de código con intenciones destructivas, de espionaje o extorsión.
- **MFA (Autenticación Multifactor):** Requerimiento de múltiples evidencias de validación pertenecientes a al menos dos factores diferentes para aprobar el acceso.
- **Man-in-the-Middle (MitM):** Ataque de interposición donde el agresor se sitúa de forma transparente en el canal de comunicación entre dos extremos para escuchar o alterar el flujo.
- **Mitigación de Riesgos:** Implementación de contramedidas técnicas u organizativas destinadas a reducir la probabilidad de impacto de una amenaza.

N

- **NSA (National Security Agency):** Organismo de inteligencia estadounidense con un rol históricamente destacado en la investigación criptográfica y de ciberseguridad defensiva y ofensiva.
- **NAT (Network Address Translation):** Traducción de direcciones de red empleada para mapear espacios de direcciones IP públicas y privadas.

O

- **Ofuscación:** Alteración sintáctica o estructural de código fuente o binario para dificultar su ingeniería inversa y análisis estático.
- **OWASP:** Fundación internacional dedicada a la seguridad de aplicaciones web, célebre por su publicación periódica del Top 10 de riesgos críticos.

P

- **Pharming:** Redirección maliciosa de dominios web legítimos hacia plataformas falsificadas mediante la alteración de cachés DNS o configuraciones locales.
- **Privacidad de Datos:** Conjunto de normativas y salvaguardas técnicas que garantizan el tratamiento legítimo y confidencial de la información personal de los usuarios.
- **Penetration Testing (Pruebas de Penetración):** Simulación controlada y acotada en el tiempo de un ataque real contra una organización para medir su postura de seguridad.

Q

- **Quarantine (Cuarentena):** Aislamiento preventivo de archivos maliciosos detectados por herramientas de seguridad para neutralizar su capacidad de ejecución.

R

- **Ransomware:** Variante de malware cifrador que bloquea el acceso a los datos de la víctima bajo la extorsión de un pago económico a cambio de la clave de descifrado.
- **Red Team:** Equipo ofensivo multidisciplinario enfocado en simular adversarios avanzados con objetivos específicos de negocio y sigilo absoluto.
- **Reconocimiento (Reconnaissance):** Fase inicial de obtención de información de fuente abierta e inteligencia técnica sobre los objetivos a auditar.
- **Rootkit:** Conjunto de binarios modificados diseñados para camuflar procesos, conexiones y ficheros maliciosos obteniendo privilegios de kernel en el sistema operativo.

S

- **Seguridad Perimetral:** Conjunto de dispositivos y filtros colocados en los límites de la red corporativa para contener el tráfico exterior no validado.
- **Spear Phishing:** Variante dirigida y altamente personalizada de phishing enfocada en objetivos específicos (ej. directivos o personal financiero).
- **SQL Injection:** Fallo crítico en aplicaciones web que permite la inserción de sentencias SQL maliciosas dentro de los parámetros de entrada para manipular bases de datos.
- **SOC (Security Operations Center):** Centro centralizado de operaciones de seguridad responsable de la supervisión continua y el triaje de alertas de seguridad.
- **Spoofing:** Suplantación de identidad en diferentes capas del modelo OSI (IP, MAC, DNS, correo electrónico) para engañar a sistemas o usuarios.

T

- **Troyano:** Software que simula una utilidad legítima pero que integra funcionalidades ocultas para comprometer el equipo host.
- **Tácticas, Técnicas y Procedimientos (TTP):** Taxonomía estandarizada que describe el comportamiento operativo, herramientas y métodos habituales de los grupos de amenaza.

U

- **Update de Seguridad:** Paquete correctivo publicado por los fabricantes para subsanar vulnerabilidades reportadas en sus plataformas.
- **Uptime:** Métrica de disponibilidad que mide el intervalo temporal ininterrumpido en el que un servicio se encuentra operativo.

V

- **Vulnerabilidad:** Defecto de diseño, implementación o configuración en un activo tecnológico susceptible de ser aprovechado por una amenaza.
- **Virus:** Código malicioso que requiere la intervención del usuario o la ejecución de un archivo huésped para replicarse y propagarse.

- **VPN (Virtual Private Network):** Tecnología que encapsula y cifra el tráfico de red permitiendo conexiones seguras a través de redes públicas como internet.

W

- **WIFI Hacking:** Auditoría y explotación de protocolos de cifrado y autenticación en redes inalámbricas (WEP, WPA/WPA2/WPA3).
- **Worm (Gusano):** Programa autónomo capaz de autorreplicarse y propagarse de manera masiva a través de la red sin requerir interacción humana directa.
- **Whitelisting:** Política estricta de control de ejecución que bloquea por defecto cualquier componente que no esté explícitamente autorizado en una lista blanca.

X

- **XSS (Cross-Site Scripting):** Vulnerabilidad de inyección de código en aplicaciones web que permite ejecutar scripts maliciosos en el navegador de otros usuarios legítimos.

Y

- **Yara:** Motor de reglas orientado a la investigación y clasificación de muestras de malware mediante patrones textuales o hexadecimales.

Z

- **Zero-Day:** Vulnerabilidad de seguridad de absoluta novedad y desconocimiento público para el desarrollador, carente por tanto de parche o mitigación oficial al momento de su explotación.